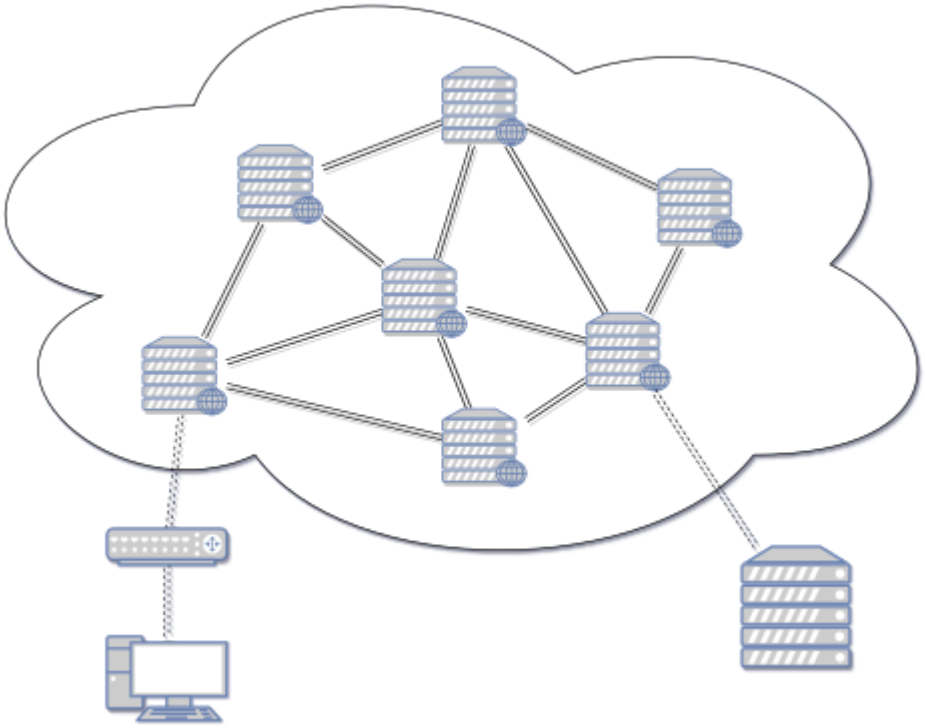
Sécurisation des communications

Communications sur Internet

Sur internet, les données échangées sont découpées en paquets (protocole TCP ou UDP) qui sont relayés par des routers jusqu'à leur destinataires (protocole IP).



Chaque router peut donc intercepter des paquets pour en connaitre le contenu, TCP/IP pose donc plusieurs problèmes de sécurité des communications pendant l'échange de données sensibles (bancaires, médicales, etc.) :

- Confidentialité : s'assurer que des informations confidentielles ne soient pas divulguées ;
- Authenticité : s'assurer que l'émetteur est bien l'auteur du message (signature) ;
- Intégrité : s'assurer que les informations échangées ne sont pas modifiées de façon malveillante.

Cours

La **cryptographie** permet de protéger les messages (confidentialité, authenticité et intégrité) à l'aide de secrets appelés clés de chiffrement.

Le **chiffrement** des communications consiste à rendre un message incompréhensible en utilisant une **clé de chiffrement**.

Le **déchiffrement** consiste à retrouver le message original en utilisant la clé de chiffrement. Lorsqu'on peut retrouver le message sans la clé (piratage informatique), on parle de **décryptage**.

On fera attention à ne pas confondre chiffrement/déchiffrement avec coder/décoder[1] et à éviter l'anglicisme *crypter* parfois utilisé au lieu de chiffrer.

On peut visionner « Comprendre le chiffrement SSL / TLS avec des emojis (et le HTTPS) ».

Cryptographie symétrique

Cours

La **cryptographie symétrique**, également appelée « **à clé secrète** », est la plus ancienne forme de chiffrement. Elle permet à la fois de chiffrer et de déchiffrer des messages à l'aide d'une **même clé**.

Si Alice (A) veut envoyer un message chiffré à Bob (B)[2] elle doit lui communiquer un mot de passe : la clé de chiffrement).

Ainsi, Alice peut aussi déchiffrer un message en provenance de Bob avec la même clé. Mais il faut au préalable trouver un moyen sûr de transmettre la clé à l'abri des regards. La situation peut cependant devenir complexe, si Alice doit envoyer un message chiffré à Bob et à Charlie mais qu'elle ne souhaite pas donner la même clé à Charlie. Plus le nombre de personnes est grand, plus il est difficile de gérer les clés symétriques, car il faut autant de clés que de correspondants. D'autant qu'il faut au préalable trouver un moyen sûr de transmettre la clé.

Exemples :

- RC4 l'algorithme utilisé pour sécuriser les communication WiFi en WEP ;
- Data Encryption Standard (DES) n'est plus utiisé ;
- Advanced Encryption Standard (AES) actuellement le plus utilisé et le plus sûr (par exemple par WPA2 pour le Wifi , Windows Bitlocker pour chiffrer un disque dur, LastPass ou Dahslane pour les gestionnaire de mots de passe, etc.).

Cryptographie asymétrique

Pour résoudre le problème de l'échange de clés, la cryptographie asymétrique a été mise au point dans les années 1970.

Cours

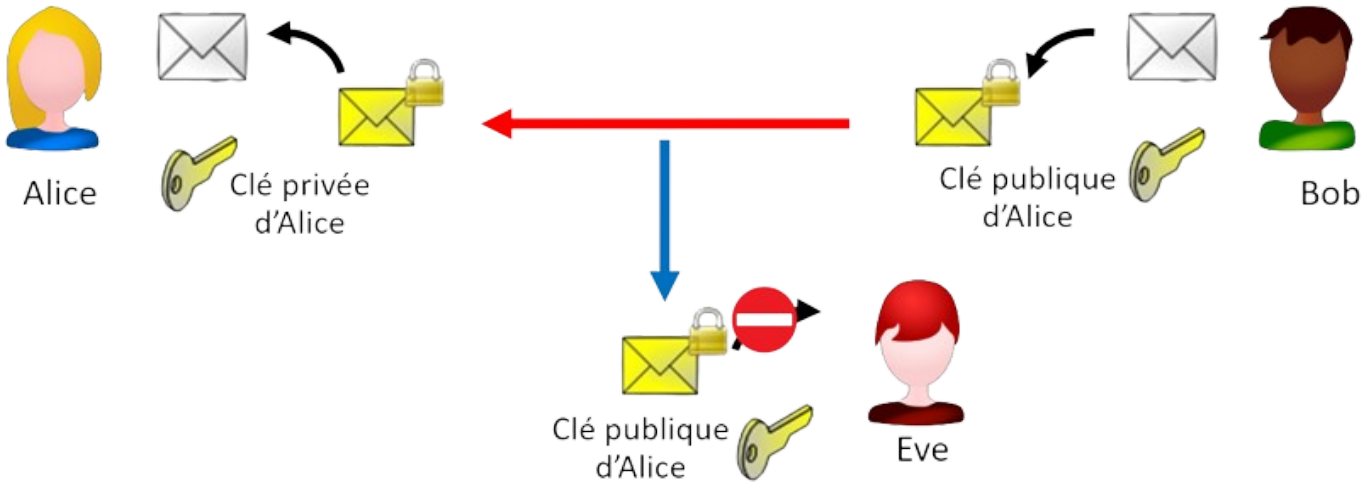
La **cryptographie asymétrique**, également appelée « **à clé publique** », se base sur le principe de deux clés :

- une **clé publique**, mise à la disposition de quiconque et permettant le chiffrement ;
- une **clé privée**, qui doit rester confidentielle et permettant le déchiffrement.

Ceci est une convention, le rôle des clés est **interchangeable** : un message chiffré avec une clé (publique ou privée) peut-être déchiffrée avec l'autre (resp. clé privée ou publique).

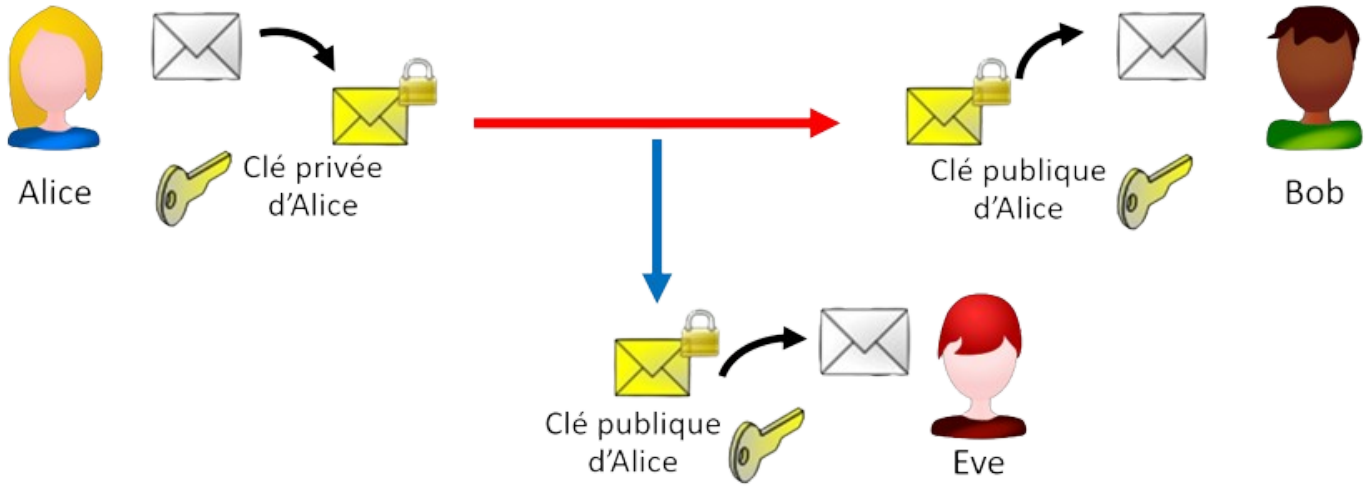
Le système permet de :

- **chiffrer** le message à envoyer : l'expéditeur utilise la clef publique du destinataire pour coder son message. Le destinataire utilise sa clef privée pour décoder le message de l'expéditeur, garantissant la confidentialité du contenu.



Alice peut lire le message en provenance de Bob en le déchiffrant avec sa clé privée. Elle est la seule à pouvoir le faire, Eve ne peut pas.

- s'assurer de l'**authenticité** de l'expéditeur : L'expéditeur utilise sa clef privée pour coder un message que le destinataire peut décoder avec la clef publique de l'expéditeur ; c'est le mécanisme utilisé par la **signature numérique** pour authentifier l'auteur d'un message.



Alice peut signer ses messages. Bob est certains qu'elle est l'auteure des messages qu'il reçoit. Le chiffrement asymétrique repose sur des problèmes mathématiques très difficiles à résoudre dans un sens et faciles à résoudre dans l'autre sens.

Quelques algorithmes de cryptographie asymétrique très utilisés :

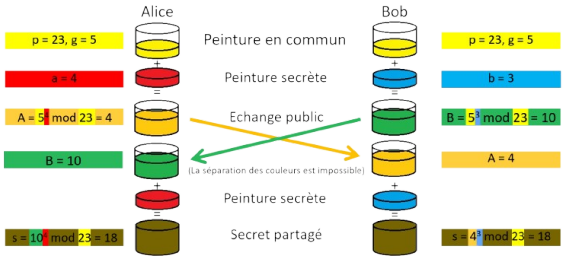
- RSA (chiffrement et signature) le plus courant ;
- Echange de clés Diffie-Hellman (échange de clé) ;

Un autre exemple de cryptographie asymétrique : Échange de clés Diffie-Hellman

L'algorithme de Diffie-Hellman est basé sur des théories mathématiques avancées mais on peut en donner une explication intuitive en faisant une analogie avec des couleurs. Cette explication est imagée et n'a pas de sens pratique, mais permet de comprendre l'essence de l'échange de clés Diffie-Hellman.

L'objectif est qu'Alice et Bob se mettent d'accord sur une couleur secrète, sans qu'Ève ne puisse la connaître. On suppose que les agents peuvent mélanger des couleurs, mais qu'il est difficile (notamment pour Ève !) d'extraire les couleurs utilisées pour réaliser un mélange. Le principe est le suivant :

1. Alice et Bob choisissent au préalable une peinture commune, ici le jaune. Cette couleur est connue de tous, y compris de l'intrus Ève.
2. Alice choisit une autre couleur secrète (ici du rouge). Elle mélange la peinture commune et sa couleur secrète et obtient de l'orange. Alice envoie la couleur orange à Bob. La couleur orange est connue d'Ève.
3. Bob fait de même : il choisit une couleur secrète (ici du cyan) qu'il mélange à la peinture commune et il obtient du bleu. Bob envoie sa couleur, le bleu, à Alice. La couleur bleue est connue d'Ève.
4. Alice prend la couleur reçue (le bleu) qu'elle mélange avec sa couleur secrète rouge. Elle obtient une couleur brune.
5. Bob prend la couleur reçue (l'orange) qu'il mélange avec sa couleur secrète cyan. Il obtient la même couleur brune.



A la fin du protocole, Alice et Bob possèdent la même couleur brune, qui représente la couleur secrète partagée. En supposant qu'il est difficile pour Ève d'extraire les couleurs utilisées pour obtenir les couleurs publiques orange et bleue, Ève ne connaît pas la couleur brune finale.

Le principal inconvénient de RSA et des autres algorithmes à clés publiques est leur grande lenteur par rapport aux algorithmes à clés secrètes. RSA est par exemple 1000 fois plus lent que DES. En pratique, dans le cadre de la confidentialité, on s'en sert pour chiffrer un nombre aléatoire qui sert ensuite de clé secrète pour un algorithme de chiffrement symétrique.

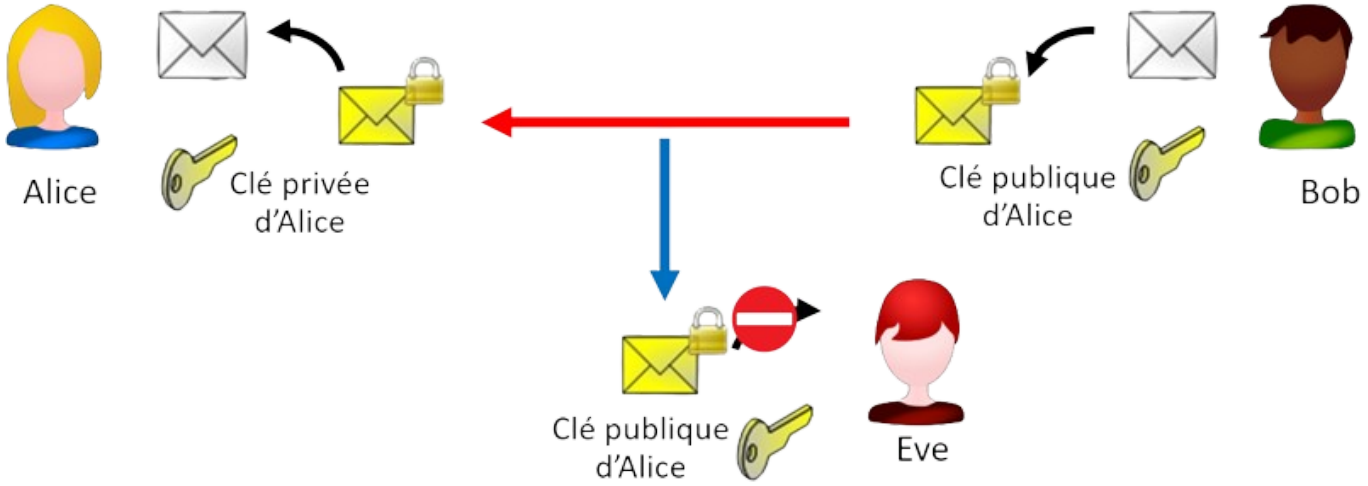
Attaque de l'homme du milieu et certificat d'authentification

Cours

L'**attaque de l'homme du milieu** ou ***man-in-the-middle*** (MITM) est une attaque qui a pour but d'intercepter les communications entre deux parties, sans que ni l'une ni l'autre ne puisse se douter que le canal de communication entre elles a été compromis

Alice et Bob veulent échanger des données confidentielles mais Eve veut les intercepter. Ils possèdent chacun une clé privée (respectivement $Clé_{Aprivé}$, $Clé_{Bprivé}$ et $CléE_{privé}$) et une clé publique (respectivement $Clé_{Apublique}$, $Clé_{Bpublique}$ et $Clé_{Epublique}$).

Alice et Bob échangent leur clé publique. Eve[3] peut les lire, elle connaît donc $Clé_{Apublique}$ et $Clé_{Bpublique}$. Comme on l'a vu auparavant, si Bob veut envoyer un message à Alice, il chiffre ce message avec $Clé_{Apublique}$. Alice le déchiffre avec $Clé_{Aprivé}$. Eve, qui ne possède pas $Clé_{Aprivé}$, ne peut pas lire le message.



Admettons maintenant que Eve soit en mesure de modifier les échanges entre Alice et Bob.

- Alice envoie sa clé publique à Bob. Eve l'intercepte et renvoie à Bob sa propre clé publique ($Clé_{Epublique}$) en se faisant passer pour Alice.
- Lorsque Bob veut envoyer un message à Alice, il utilise donc, sans le savoir, la clé publique d'Eve.
- Bob chiffre le message avec la clé publique de Eve et l'envoie à celui qu'elle croit être Alice.
- Eve intercepte le message, le déchiffre avec sa clé privée ($CléE_{privé}$) et peut lire le message.
- Puis elle chiffre à nouveau le message avec la clé publique d'Alice ($Clé_{Apublique}$), après l'avoir éventuellement modifié.
- Alice déchiffre son message avec sa clé privée, et ne se doute de rien puisque cela fonctionne. Ainsi, Alice et Bob sont chacun persuadés d'utiliser la clé de l'autre, alors qu'ils utilisent en réalité tous les deux la clé d'Eve.

Afin de sécuriser entièrement les communications entre deux participants, il ne suffit pas seulement de les chiffrer, mais il faut aussi que chaque participant puisse s'assurer de l'identité de son correspondant : c'est le rôle des certificats d'authentification.

Certificats et Autorités de Certification

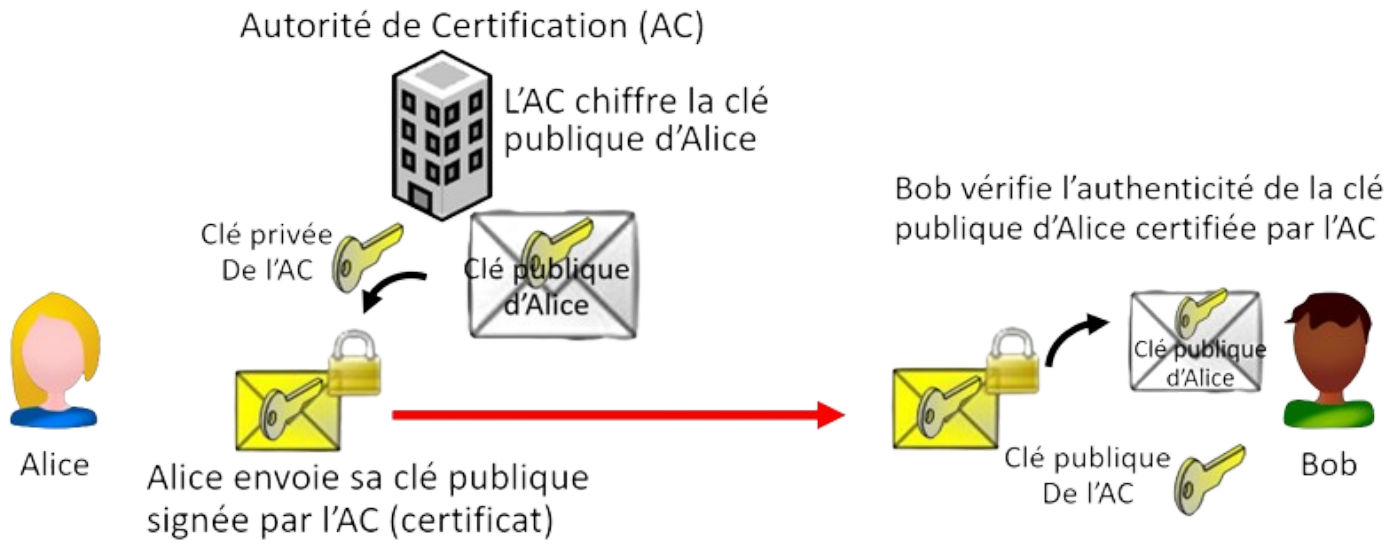
Cours

Un **certificat d'authentification** (ou certificat SSL ou TLS) permet d'associer avec certitude une clé publique avec son **véritable propriétaire** (site Web, entreprise, individu) afin de sécuriser les échanges électroniques avec les utilisateurs qui s'y connectent via Internet.

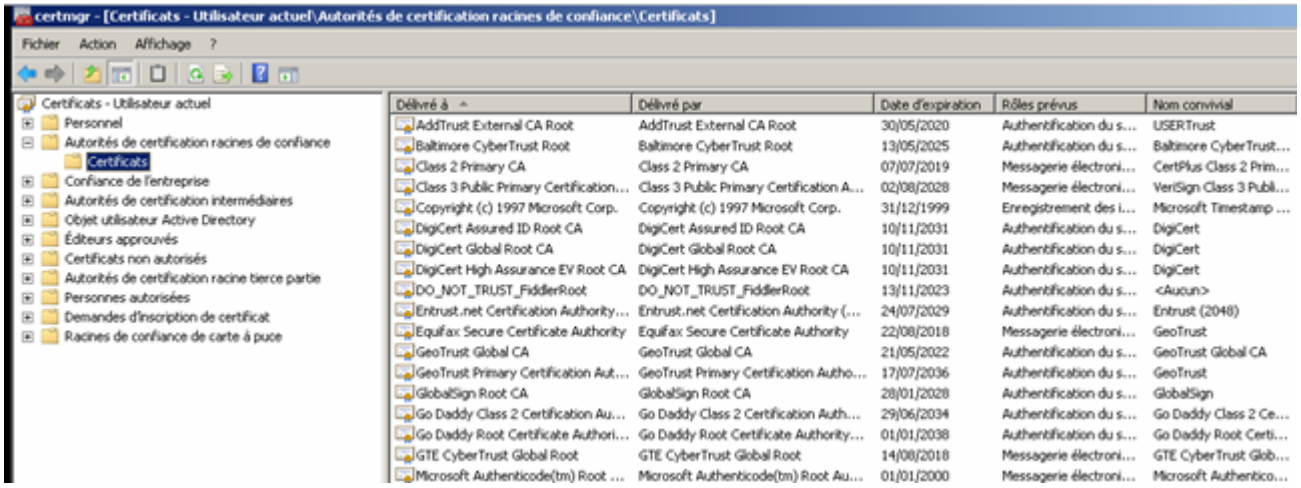
Les certificats sont délivrés pas des **Autorités de Certification (AC)** de confiance, qui agissent en quelque sorte comme une Préfecture ou une Mairie qui délivre des cartes d'identité ; elles engagent une série de vérifications afin d'établir avec certitude l'identité de l'entreprise et du serveur web.

Un certificat électronique contient la clé publique pour le site et des informations d'identification (par exemple : l'url, le nom, localisation, adresse électronique), le tout est chiffré par l'Autorité de Certification (à partir de sa clé privée), on dit qu'il est **signé**, afin de garantir l'exactitude des informations du certificat.

Les navigateurs, les systèmes d'exploitation et les appareils mobiles tiennent à jour la liste de clés publiques des Autorités de Certification. Ces clés sont appelées **clés publiques racines** ou **certificats racines**. Le certificat racine doit être présent sur la machine de l'utilisateur final pour être considéré fiable, sinon le navigateur affiche des messages d'alerte indiquant qu'il ne faut pas lui faire confiance. Il y a un peu plus d'une centaine d'AC reconnues par les navigateurs et systèmes d'exploitation.



Sous Windows, la commande certmgr.msc permet de voir la liste des certificats racines stockés sur l'ordinateur.



HTTPS

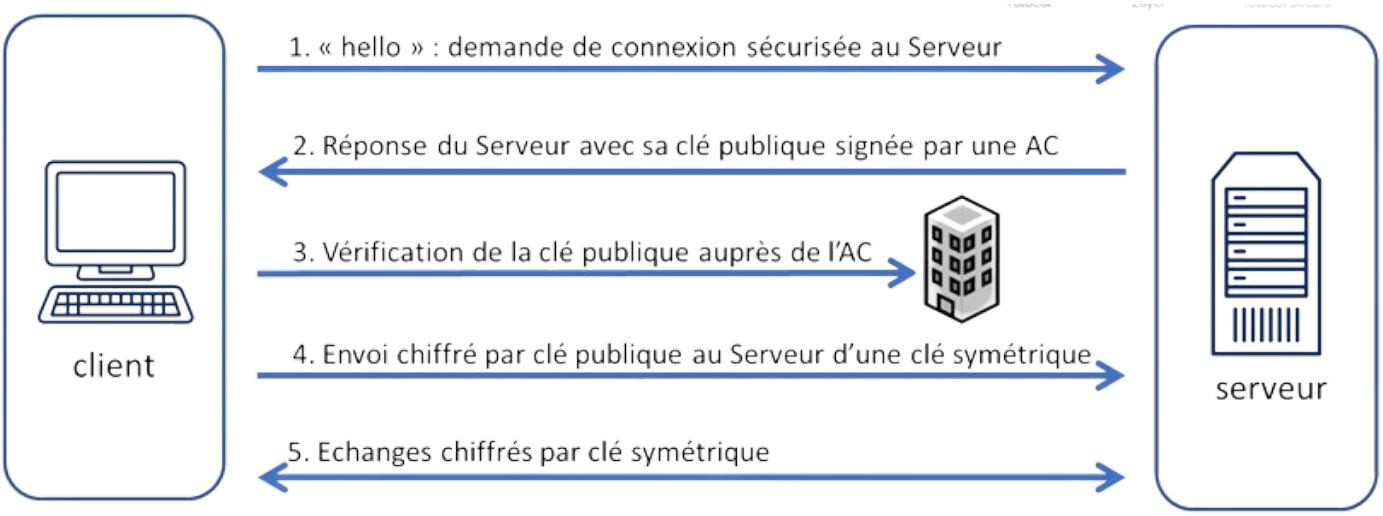
Cours

HTTPS (HyperText Transfer Protocol Secure) est la combinaison du protocole de base du Web HTTP avec les protocoles de chiffrement SSL (Secure Socket Layer) puis de son successeur TLS (Transport Layer Security).

Il permet :

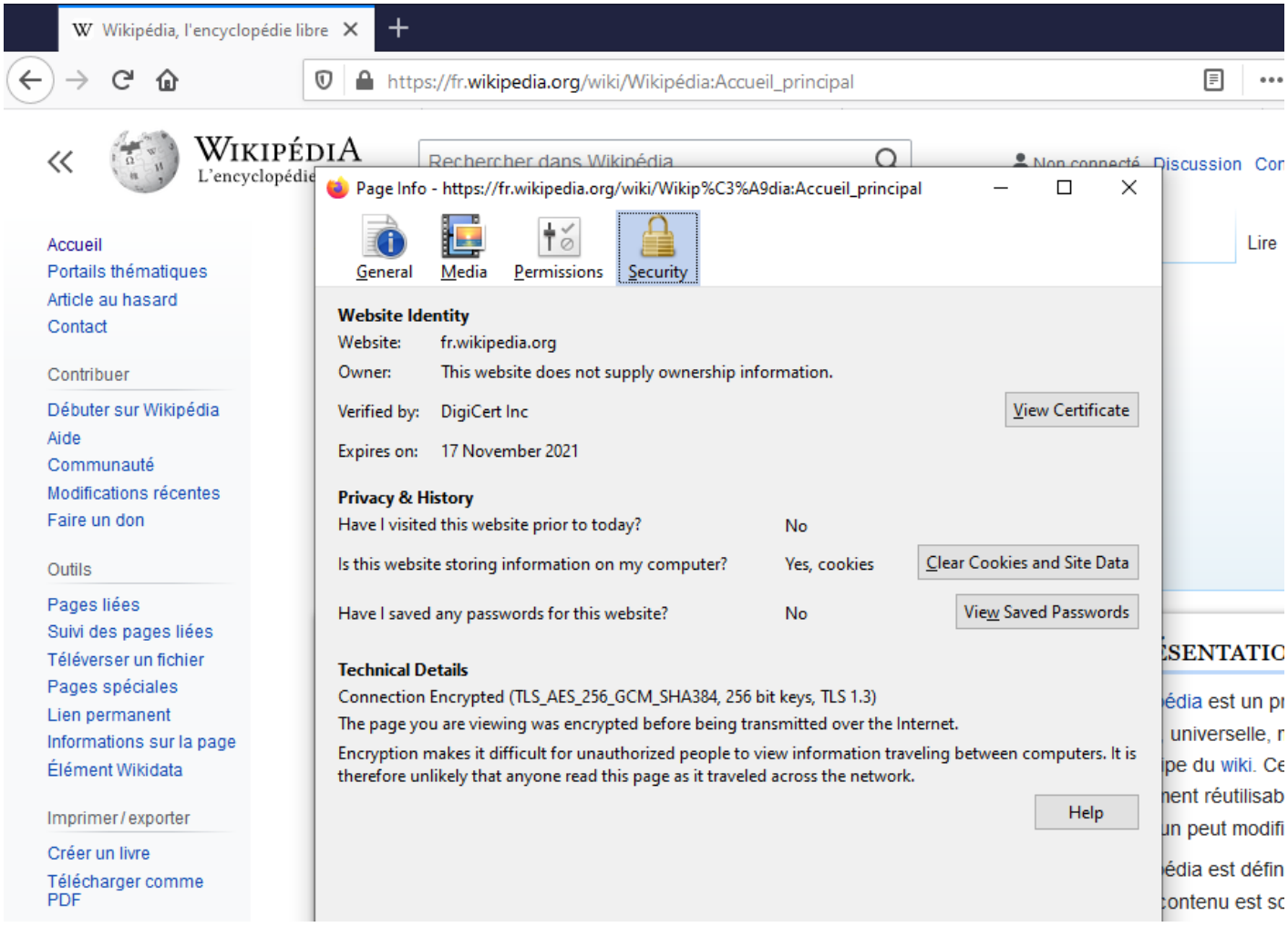
- A un visiteur de vérifier l'identité du site web auquel il accède, grâce à un certificat d'authentification émis par une autorité tierce, réputée fiable (et faisant généralement partie de la liste blanche des navigateurs internet) ;
- De garantir la confidentialité et l'intégrité des données envoyées par l'utilisateur (notamment des informations entrées dans les formulaires) et reçues du serveur.
- De valider l'identité du visiteur, si celui-ci utilise également un certificat d'authentification client.

Avant que le client et le serveur ne puissent initier une communication sécurisée, ils doivent passer par une procédure nommée « négociation TLS » – le résultat étant une clé de session symétrique qui sera utilisée par le client et par le serveur pour chiffrer et déchiffrer des transmissions.



1. le client —un navigateur Web — envoie un message initial (nommé « hello ») à un serveur — par exemple Wikipédia — et demande une connexion sécurisée, précisant les méthodes de chiffrement qu'il accepte;
2. le serveur répond en communiquant − une méthode de chiffrement choisie parmi la liste reçue − un certificat signé par une Autorité de Certification contenant sa clé publique
3. le client vérifie que le certificat reçu a bien été signé par une AC en laquelle il fait confiance en le déchiffrant avec la clé publique de cette AC. Cette étape garantit qu'il a bien reçu la clé du serveur en question et qu'il n'est pas victime d'une attaque de l'homme du milieu
4. le client chiffre avec la clé publique reçue un message qu'il envoie au serveur pour communiquer une clé de session symétrique.
5. A ce stade, le client et le serveur se sont reconnus, ont choisi une méthode de chiffrement puis se sont échangés de manière chiffrée une clé de chiffrement symétrique : ils peuvent communiquer de manière sécurisée.

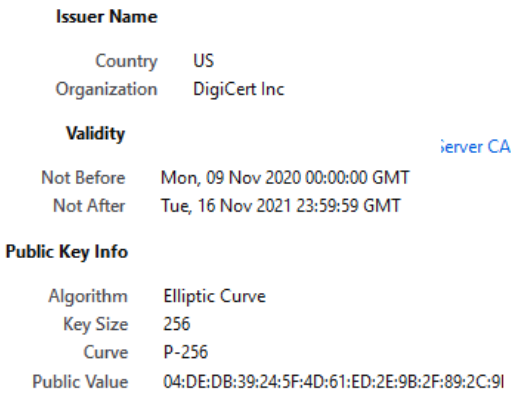
Sur Firefox par exemple on peut voir les détails d'un certificat et le chiffrement utilisé en cliquant sur le cadenas.



On peut obtenir des informations similaires avec les autres navigateurs.

Le bouton "View Certificate" permet d'obtenir les détails sur l'Autorité de Certification et le certificat utilisé.

1. L'Autorité de Certification (AC), ici Digicert, qui atteste, au moyen d'un certificat numérique, que l'entité est bien qui elle prétend être.
2. Les dates de validité du certificat.
3. La clé publique du site Web, c'est-à-dire celle qui sera utilisée par le navigateur pour chiffrer la communication initiale ainsi que l'algorithme de chiffrement, ici Elliptic Curve.



Le certificat est signé (chiffré) avec la clé privée de l'AC. Il suffira au navigateur de le déchiffrer avec la clé publique racine dont il dispose pour vérifier l'authenticité du site Web.

---

1. coder désigne la représentation des données dans un certain format, par exemple coder un entier en binaire, ou décoder un code ASCII. ↩
2. Alice et Bob forment le couple le plus connu du monde de la cryptographie ↩
3. En cryptographie le nom de Eve, pour *eavedropper* (oreille indiscrete), est souvent choisi pour désigner l'homme du milieu. ↩